Tên trường / khoa

Knowledge Base cho audit Solidity

Crawler · Finding–Evidence · Knowledge

Tên sinh viên

Báo cáo tiến độ · 30/09/2026

Mục tiêu và phạm vi

Mục tiêu

Chuyển báo cáo audit thành kiến thức có thể truy ngược về finding và code nguồn.

Hỗ trợ auditor kiểm tra nguyên nhân, điều kiện phát sinh và trường hợp báo nhầm.

Phạm vi đã thực hiện

- Crawler và pipeline evidence.
- Knowledge có trích dẫn, phiên bản và trạng thái review.
- Một pattern được kiểm chứng bằng ví dụ chạy trên EVM local.

Chưa triển khai embedding hoặc tích hợp LLM verifier vào luồng audit tự động.

Pipeline đã triển khai

Thu thập và chuẩn hóa

1. Cào findings từ Solodit và Code4rena.
2. Lưu snapshot, định danh và fingerprint.
3. Trích xuất code block và URL trong báo cáo.

Resolve và lưu evidence

4. Resolve Markdown, GitHub và Gist.
5. Kiểm tra code, ghi nhận lỗi hoặc thiếu ngữ cảnh.
6. Lưu evidence, liên kết finding và trạng thái retry/resume.

Luồng đã được kiểm chứng trên bộ mẫu đóng băng; không bảo đảm mọi finding đều lấy được code.

Bộ dữ liệu thực nghiệm

35

Findings thực tế ban đầu

20 Solodit và 15 Code4rena.

34

Findings được đánh giá

19 Solodit và 15 Code4rena.

Một mẫu bị quarantine vì nội dung lẫn nhiều findings.

Nguồn: tests/fixtures/evidence_benchmark_v1/README.md. Đây là bộ phát triển, chưa phải tập đánh giá độc lập.

26/34 findings có code evidence

Độ phủ evidence theo nguồn



Độ dài thanh biểu diễn tỷ lệ findings có evidence.

76,5%

8 findings chưa thu được code evidence.

Có evidence chưa đồng nghĩa đã xác nhận lỗ hổng.

Nguồn: data/processed/phase6-quality.json.

Kết quả resolve evidence

100 evidence không trùng

- 77 đoạn code inline.
- 22 evidence từ GitHub file.
- 1 evidence từ Gist.

Một evidence có thể được nhiều finding tham chiếu.

154 bản ghi liên kết/ứng viên

- 101 đã resolve được evidence.
- 53 còn lỗi `fixture_missing`.

Thiếu phản hồi HTTP trong bộ replay; chưa thể kết luận link chết.

Nguồn: phase4-resolution.json và phase6-quality.json; chạy bằng phản hồi HTTP đã ghi lại.

Kiểm tra code bằng parser

Trạng thái của 100 evidence

Parse thành công	**12**
Thiếu ngữ cảnh	**87**
Parser đánh dấu invalid	**1**

Kết quả theo parser và phiên bản đã lưu.

Code trích từ báo cáo thường là fragment.

Cần thêm caller, khai báo hoặc dependency để đánh giá đầy đủ.

Nguồn: phase5-validation.json. Parse thành công không chứng minh compile thành công hoặc có lỗ hổng.

Knowledge cho finding và evidence

Nội dung cần có

- Nguyên nhân gốc.
- Tiền điều kiện và điều kiện khai thác.
- Hành vi và ảnh hưởng.
- Dấu hiệu nhận diện, cách sửa.
- Giới hạn và trường hợp báo nhầm.

Khả năng truy vết

Mỗi claim gắn với snapshot, dòng và quote nguồn; có thể tham chiếu evidence link.

Lưu revision và binding link → evidence để phát hiện thay đổi nguồn.

Nhóm thông tin chưa trích xuất được được ghi nhận là thiếu; không tự điền thành kết luận.

34 knowledge candidates đang chờ review

34 candidates · 360 claims

Đã kiểm tra trích dẫn khớp nội dung và dòng trong snapshot.

0 bản đã duyệt chuyên môn.

Đúng nguồn trích dẫn chưa chứng minh nhận định đúng về bảo mật.

Nguồn: phase7-verification.json. Các draft chưa đầy đủ đồng đều tám nhóm kiến thức.

Case study: ép uint256 xuống uint128

Finding tham chiếu

Caviar H-03: Risk of silent overflow in reserves update.

Pattern xét trường hợp nghiệp vụ cần giữ chính xác giá trị khi cập nhật state.

Điều kiện cần xác minh

Giá trị thực tế có thể vượt $2^{128} - 1$ mà không bị kiểm tra trước cast.

Với giá trị runtime $\text{amount} = 2^{128}$, phép `uint128(amount)` cho kết quả 0.

Nguồn: Caviar H-03 Solidity 0.8.24 — chuyển kiểu.

Ba tình huống cần phân biệt

Không có guard	Đầu vào vượt miền vẫn được chấp nhận; giá trị lưu bị cắt → xác nhận lỗi trong fixture.
Có guard trước cast	Kiểm tra đúng giá trị gốc; vượt miền thì revert → loại trừ pattern này.
Chỉ có hàm internal	Chưa biết caller và ràng buộc đầu vào → giữ trạng thái thiếu ngữ cảnh.

Nguồn: tools/cast-pattern/pattern.json. Ví dụ synthetic; nhãn chỉ áp dụng cho pattern đang xét.

Kiểm chứng trên EVM local

4 contracts × 39 đầu vào = 156

Biên dịch bằng Solidity 0.8.24; chạy 156 giao dịch trên EVM local.

Kiểm tra receipt, giá trị lưu và state sau revert.

Cùng fragment được thử với hai caller có và không có guard.

Nguồn: uint128-pattern-validation.json. Chưa tái hiện PoC Caviar gốc hoặc chứng minh thiệt hại tài chính.

Dữ liệu bàn giao và truy xuất

Số liệu và ví dụ

- `phase6-quality.json`: chất lượng evidence.
- `phase7-verification.json`: knowledge.
- `phase7-example.md`: case study dễ đọc.

Các file nằm trong `data/processed/`.

Dữ liệu đầy đủ

SQLite: `phase4-replay.sqlite3` trong `data/checkpoints/`.

Lưu snapshot, code evidence, liên kết, processing state và knowledge revisions.

Dữ liệu đầu vào và provenance: tests/fixtures/evidence_benchmark_v1/.

Giới hạn và bước tiếp theo

Giới hạn hiện tại

- Bộ phát triển có quy mô nhỏ.
- Replay chưa phủ mọi URL.
- Knowledge chưa được duyệt.
- Chưa tích hợp LLM verifier.

Thử nghiệm tiếp theo

- Chọn project nhỏ có pattern phù hợp.
- Đọc caller, guard và invariant.
- Viết test trên project thực tế.
- Review và mở rộng pattern.

Hiện có thể hỗ trợ kiểm tra một pattern; chưa phải quy trình audit bảo mật toàn diện.

Đã có luồng crawler → evidence → knowledge candidate.

Bước tiếp theo: kiểm chứng trên project thực tế và review kiến thức.